Flag 17 of 18: Telemetry-Style Exfiltration Domain

Rogue Synthesis scenario · Cymbal Investments · Google SecOps SIEM

Question

Shortly after the local tokens were harvested on the workstation, the stolen data was exfiltrated via an outbound HTTP POST request to an external URI path masquerading as a telemetry endpoint. To what external domain was the data sent?

Answer

dev-metrics-cdn.com

Evidence

- A Zscaler proxy event for `alex.chen` to `dev-metrics-cdn.com`, shown at 21:53:51 in the list view (about 20:53:51Z), roughly seven minutes after `credentials.db` was read at 20:46:21Z.
- The name sounds like a telemetry or CDN service, which fits the "masquerading as a telemetry endpoint" clue. It is not a domain alex.chen tools normally use.
- The other two results in the same window were ruled out: `slack.com` is a normal business application, and `cr.cymbal.corp` is the internal container registry.
- Evidence status: the answer was accepted in the platform. The event fields (full URL path, method, bytes sent) were not pasted in this session, so open the event to confirm a `POST` to a telemetry-style path.

How it was found

Window: Oct 15 20:46 to Oct 16 00:00 UTC. A search for alex.chen web requests after the token read returned three destinations:

```
principal.namespace = "Cymbal"
AND metadata.event_type = "NETWORK_HTTP"
AND (principal.user.userid = "alex.chen" OR principal.ip = "10.240.12.80")
```

Lesson

Filter out the destinations the user tools normally contact (Microsoft, GitHub, Slack, internal hosts). The odd, unfamiliar domain right after the credential read is the exfiltration target.

Next pivot

The registry connection (`cr.cymbal.corp`) and the service account `svc_cicd_deploy` reaching `CYM-CI-RUNNER-01` come next.